Microsoft Purview Audit (Standard & Premium) — Unified Audit Log & Investigations

Implementation Solution Guide

Version 1.0.0 · 2026-07-07

Contents

Executive Summary — Microsoft Purview Audit (Standard & Premium) 5

The problem . . . 5

The solution . . . 5

What you get . . . 5

Approach . . . 5

Boundaries . . . 5

The bottom line . . . 6

1. Solution Overview — Microsoft Purview Audit (Standard & Premium): Unified Audit Log & Investigations 6

What this solution is . . . 6

Why this matters . . . 6

How it works . . . 7

The audit stack this solution configures . . . 7

What you can control . . . 7

Limitations (be honest with buyers) . . . 8

Naming convention (used in every doc and script) . . . 8

The standard deployment model . . . 9

2. Requirements Guide — Microsoft Purview Audit (Standard & Premium) 9

2.1 Compliance licensing for the audit tier you need . . . 9

2.2 Audit roles (least-privilege) . . . 9

2.3 Exchange Online PowerShell + Security & Compliance PowerShell + Graph . . . 10

2.4 Unified audit logging enabled . . . 10

2.5 Mailbox auditing on (and no unexpected bypass) . . . 10

2.6 Defined retention & investigation requirements (from compliance/legal) . . . 10

2.7 SIEM / export target and its identity (if exporting) . . . 11

2.8 A pilot scope and change window . . . 11

Global Requirements — Microsoft Purview Solutions 11

1. Microsoft 365 tenant with the required Purview/compliance licensing . . . 12

2. Purview roles (least-privilege) and portal access . . . 12

3. Security & Compliance PowerShell + Graph toolchain . . . 12

4. Data sources & scope in scope . . . 12

5. Compliance, records, privacy & legal stakeholders . . . 13

6. A pilot scope and change control . . . 13

3. Implementation Guide — Microsoft Purview Audit (Standard & Premium) 13

Step 1 — Assess the current audit state and licensing (Assess) . . . 14

Step 2 — Design the retention and investigation coverage (Design) . . . 14
Step 3 — Enable the foundation: unified audit + mailbox auditing (Configure) . . . 14
Step 4 — Configure audit log retention policies (Configure) . . . 15
Step 5 — Validate high-value events are being captured (Configure → Pilot) . . . 15
Step 6 — Build the investigation runbooks (Configure) . . . 15
Step 7 — Wire SIEM/export (Configure → Pilot) . . . 16
Step 8 — Validate investigation-readiness (Validate) . . . 16
Step 9 — Expand and operationalize (Expand) . . . 17
5. Testing & Validation — Microsoft Purview Audit (Standard & Premium) 17
Gate 1 — Unified audit logging is on . . . 17
Gate 2 — Mailbox auditing on, no unexpected bypass . . . 17
Gate 3 — Audit Premium licensing where expected . . . 18
Gate 4 — High-value events are being captured . . . 18
Gate 5 — Retention policies exist and are correct . . . 18
Gate 6 — Search returns complete (non-truncated) results . . . 18
Gate 7 — Investigation runbooks answer their questions . . . 18
Gate 8 — Export/SIEM is flowing (if configured) . . . 19
Gate 9 — Readiness scorecard is green . . . 19
Evidence to retain . . . 19
6. Troubleshooting — Microsoft Purview Audit (Standard & Premium) 19
Search returns nothing for a user you know was active . . . 19
Search returns far fewer results than expected (truncation) . . . 20
`UnifiedAuditLogIngestionEnabled` won't flip to True / is slow . . . 20
`MailItemsAccessed` still missing after licensing looks right . . . 20
Retention policy cmdlet not found / "term not recognized" . . . 20
Retention policy create fails on duration or priority . . . 20
Retention policy doesn't seem to keep events . . . 21
Audit visible for some admins but not others . . . 21
Management Activity API export: token or permission errors . . . 21
SIEM shows no data even though subscriptions are "enabled" . . . 21
Timestamps don't line up with other logs . . . 21
When to escalate beyond this solution . . . 21
7. Best Practices — Investigation-Ready Auditing with Microsoft Purview 22
Configure it before you need it . . . 22
Understand — and license for — the events you'll actually need . . . 22
Retention: deliberate, priority-ranked, and governed . . . 22

Watch the gotchas that make audit "find nothing" . . . 22
Standardize investigations as runbooks . . . 23
Export for durability and monitoring — but keep identities clean . . . 23
Least-privilege roles and separation . . . 23
Pilot every change, keep a rollback . . . 23
8. Deliverables Summary — Microsoft Purview Audit (Standard & Premium) 23
Documentation . . . 24
PowerShell tools (5) . . . 24
Named artifacts created . . . 25
Definition of done . . . 25
Appendix A — PowerShell Scripts 26

Executive Summary — Microsoft Purview Audit (Standard & Premium)

The problem

Every investigation — a compromised mailbox, a departing employee suspected of taking data, a questionable admin action — begins with the same question: *what does the audit trail show?* Too often the answer arrives too late: unified audit logging was never confirmed on, the high-value events an investigation needs were never captured, retention was too short, or nobody had a repeatable way to search. **Audit is not retroactive** — if it wasn't configured before the incident, the evidence simply isn't there.

The solution

A complete, self-guided implementation of **Microsoft Purview Audit**. It confirms and enables **unified audit logging**, establishes what **Audit Premium** (E5 / add-on) provides — the high-value events that matter most, above all `MailItemsAccessed` (which messages an attacker actually read), plus longer retention — configures **audit log retention policies**, builds tested **investigation runbooks** for the common incident questions, and wires **SIEM export** via the Office 365 Management Activity API. Five safe-by-default PowerShell tools (read-only or `-WhatIf` until you commit) do the assessment, configuration, searching, readiness reporting, and export.

What you get

- **Standard vs Premium, made concrete** — what each retains, which events each unlocks, and which of your users need Premium for forensic-grade auditing.
- **The foundation confirmed** — unified audit logging on, mailbox auditing on, no hidden audit-bypass suppressing a user's events.
- **Deliberate retention** — priority-ranked policies keeping privileged actions and mailbox high-value events for the duration your compliance and legal functions require.
- **Investigation runbooks** — the exact operations and record types for mailbox compromise, data exfiltration, and privilege escalation, with a paged search tool that never silently truncates results.
- **Continuous export** — audit streamed to your SIEM for real-time detection and durable retention.
- **Proven readiness** — a scorecard that confirms you can answer the questions an incident will ask, before it asks them.

Approach

Delivery follows a disciplined, reversible model — **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** — enabling, retaining, and exporting **pilot-first** on a limited scope before any tenant-wide change, with pass/fail gates and documented rollback at every step.

Boundaries

Microsoft Purview Audit is **licensing-/plan-dependent** (Premium features require E5 or the E5 Compliance / Audit add-on, assigned per user) and the portal and search tooling are **actively evolving** — capabilities and paths are cited or flagged **"verify your licensing/tenant,"** never assumed. **Retention-schedule adequacy, legal-hold obligations, and regulatory determinations are deferred to your compliance, records, privacy, and legal functions** — the solution provides the technical method and the evidence, not the determination.

The bottom line

An audit trail ready **before** you need it — unified logging on, high-value events captured and retained, investigation runbooks in hand — so an incident finds **answers, not gaps**.

1. Solution Overview — Microsoft Purview Audit (Standard & Premium): Unified Audit Log & Investigations

What this solution is

When something goes wrong — a compromised mailbox, a departing employee suspected of taking data, an over-privileged admin action — the first question is always *"what does the audit trail show?"* Too many organizations discover the answer too late: unified audit logging was never confirmed on, the high-value events an investigation needs were never captured, retention was too short, or nobody had a repeatable way to search. This solution implements **Microsoft Purview Audit** end to end: confirm and enable **unified audit logging**, understand and (where licensed) enable **Audit Premium** for high-value events and longer retention, configure **audit log retention policies**, build repeatable **search and investigation runbooks**, wire **SIEM/export** via the Office 365 Management Activity API, and validate that you can actually answer the questions an incident will ask — *before* it asks them. It uses only the **Microsoft Purview portal**, **Exchange Online / Security & Compliance PowerShell**, and **Microsoft Graph** — no third-party tooling.

Why this matters

- Audit is the evidence layer for every investigation. If it wasn't configured before the incident, the data simply isn't there — audit is not retroactive.
- **Audit Standard** now retains most records for 180 days; **Audit Premium** extends default retention to one year (up to ten years with the add-on) and unlocks **high-value events** — most importantly `MailItemsAccessed`, which tells you *whether and which* messages an attacker actually read after compromising a mailbox. Without it, mailbox-compromise scope is guesswork.
- The controls are **licensing-dependent and evolving**. Audit Premium features require Microsoft 365 E5 or the E5 Compliance / Audit add-on, and Microsoft is transitioning search tooling (portal, `Search-UnifiedAuditLog`, and the newer Graph Audit Log Query API). Getting this right means confirming what your tenant actually has, not assuming.
- Auditing is only useful if someone can query it under pressure. A tested **investigation runbook** — the exact operations and record types for mailbox compromise, data exfiltration, and privilege escalation — turns a panic into a procedure.

How it works

1. **Confirm the foundation.** Unified audit logging is on by default for newer tenants, but it can be disabled and it varies — the solution verifies `UnifiedAuditLogIngestionEnabled` and org-level mailbox auditing, and enables them if off.

2. **Establish the licensing reality.** Which workloads and users have **Audit Premium** (E5 / Audit add-on) is read from Graph, because `MailItemsAccessed` and long-term retention only apply where the license is assigned.

3. **Configure retention deliberately.** Beyond the default retention, **audit log retention policies** (priority-ranked, per record type / operation / user) keep the events that matter — privileged actions, mailbox high-value events, sign-ins — for the duration your compliance and legal functions require.

4. **Build investigation runbooks.** For the common incident questions, the solution names the exact **operations** and **record types** to search (e.g. `MailItemsAccessed`, `New-InboxRule`, `FileDownloaded`, `Add member to role`, `Consent to application`) and delivers a paged search tool so results aren't silently truncated.

5. **Wire export to a SIEM.** For continuous monitoring and retention beyond the audit store, audit data is streamed via the **Office 365 Management Activity API** (or a native connector such as Microsoft Sentinel) — the solution manages the content subscriptions.

6. **Validate readiness.** A readiness report scores the tenant against concrete gates — logging on, Premium where expected, high-value events present in recent data, retention policies covering the key record types, export active — so "investigation-ready" is proven, not assumed.

The audit stack this solution configures

• **Unified audit log** — the single searchable log of user and admin activity across Exchange, SharePoint, OneDrive, Teams, Entra ID, and more.

• **Audit (Standard)** — included with most subscriptions; ~180-day retention, core operations.

• **Audit (Premium)** — E5 / add-on; **high-value events** (`MailItemsAccessed`, `Send`, `SearchQueryInitiatedExchange`/`SharePoint`), **one-year default retention** (up to **ten years** with the add-on), **custom retention policies**, and **higher bandwidth** to the Management Activity API.

• **Audit log retention policies** — priority-ranked rules that set how long specific record types / operations / users are kept.

• **Search & investigation** — the Purview **Audit** portal search, `Search-UnifiedAuditLog` (Exchange Online PowerShell), and the newer **Audit Log Query Graph API**.

• **Export** — Office 365 **Management Activity API** content subscriptions (and native SIEM connectors).

What you can control

• Whether unified audit logging and org mailbox auditing are enabled (and confirming they stay on).

• Which record types / operations / users get **extended retention**, and for how long (within your licensing).

• The **investigation runbooks** — which operations map to which incident questions.

• The **export target** and which content types stream to your SIEM.

• The **pilot scope** (a small investigator group / limited record set) validated before any tenant-wide retention or export change.

Limitations (be honest with buyers)

• **Audit is not retroactive.** Enabling logging or Premium today does not create history for yesterday — value accrues from the enablement date forward. This is the single most important reason to configure it *before* an incident.

• **Premium features are license-gated per user.** `MailItemsAccessed` and long-term retention only apply to mailboxes/users with the E5 / Audit add-on assigned; unlicensed users won't have high-value events. **Verify your licensing/tenant.**

• **Retention-policy durations and the ten-year tier depend on licensing.** The ten-year retention add-on is a separate license; accepted `RetentionDuration` values should be **verified in your tenant**.

• **Search tooling is transitioning.** `Search-UnifiedAuditLog` has result and throttling limits (page with `ReturnLargeSet`; keep windows short) and Microsoft has signalled a move toward the **Audit Log Query Graph API** — confirm the current, supported method for your tenant before standardizing automation on one path.

• **Retention schedules and legal-hold determinations are not ours to make.** How long audit evidence must be kept, and any legal-hold obligations, are **deferred to your compliance, records, privacy, and legal functions** — this solution provides the technical method and evidence, not the determination.

Naming convention (used in every doc and script)

Every artifact this solution creates is named `<Purpose> – <Scope> – <Stage>` and reused verbatim across the docs, scripts, and portal. The standard set:

Artifact	Name
Mailbox high-value retention policy	`Audit Retention – Mailbox High-Value – Premium`
Privileged-action retention policy	`Audit Retention – Privileged Actions – LongTerm`
Sign-in / auth retention policy	`Audit Retention – Sign-in Events – Standard+`
Mailbox-compromise investigation runbook	`Investigation – Mailbox Compromise – Runbook`
Data-exfiltration investigation runbook	`Investigation – Data Exfiltration – Runbook`
Privilege-escalation investigation runbook	`Investigation – Privilege Escalation – Runbook`

Artifact	Name
Management API content subscription	`Audit Export – Management Activity API – SIEM`
Readiness scorecard export	`Audit Readiness – Tenant – Report`
Pilot validation scope	`Audit Pilot – Investigators – Stage1`

The standard deployment model

> *Assess what auditing/licensing you actually have → design the retention and investigation coverage → configure logging, retention policies, and export → **pilot** on a limited scope in read/report mode first → validate you can answer the incident questions → expand to full retention and continuous export. Pattern: **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand.***

2. Requirements Guide — Microsoft Purview Audit (Standard & Premium)

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites (tenant/licensing, Purview roles, the S&C PowerShell + Graph toolchain, in-scope workloads, compliance/records/legal stakeholders, pilot & change control) are in `global-requirements-purview.md` — this guide adds the audit-specific detail.

> ***Licensing/tenant boundary.** Audit Premium capabilities (`MailItemsAccessed` and other high-value events, one-year default retention, custom retention policies, ten-year retention, higher Management Activity API bandwidth) require **Microsoft 365 E5** or the **E5 Compliance / Audit** add-on and are assigned **per user**. Portal paths and search tooling are **evolving** — confirm the current method and your entitlements rather than assuming. Where this guide flags "verify your licensing/tenant," do so before relying on the feature.*

2.1 Compliance licensing for the audit tier you need

Description: Audit **Standard** is included with most Microsoft 365 subscriptions; **Audit Premium** (high-value events, one-year retention, custom retention policies) requires **E5** or the **E5 Compliance / Audit** add-on, assigned to the users/mailboxes you want covered. Ten-year retention is a further add-on. **Why:** `MailItemsAccessed` and long-term retention only exist where the Premium license is assigned; unlicensed users won't generate those events (GR §1). **Verify:** M365 admin center → `Billing` → `Licenses`; and run `PURVAUDIT-Discovery.ps1`, which reads `subscribedSkus`/service plans via Graph and reports whether an Audit Premium-bearing plan is present and how many users carry it. **Implement:** Assign/purchase E5 or the Audit add-on to the in-scope users before expecting Premium events; add the ten-year add-on only if your records schedule requires it.

2.2 Audit roles (least-privilege)

Description: To **search** the audit log you need the **View-Only Audit Logs** or **Audit Logs** role (in the Exchange Online / Purview role model); the Purview **Audit Manager** and **Audit Reader** role groups package these. To **create retention policies** you need the **Audit Logs** role (write). Reserve Global

Administrator for tenant-wide enablement only. **Why:** Purview uses fine-grained roles; search, configuration, and export each need the matching role (GR §2). **Verify:** Purview portal → `Settings → Roles & scopes / Permissions` — confirm membership of Audit Reader/Manager (or the underlying roles). `PURVAUDIT-Search.ps1` reports a permissions error if the role is missing. **Implement:** Assign the least-privilege Audit role group under change control; investigators get **Audit Reader**, the configuring admin gets **Audit Manager**.

2.3 Exchange Online PowerShell + Security & Compliance PowerShell + Graph

Description: The `ExchangeOnlineManagement` module provides **both** `Connect-ExchangeOnline` (for `Search-UnifiedAuditLog`, `Get/Set-AdminAuditLogConfig`, mailbox-audit cmdlets) **and** `Connect-IPPSSession` (Security & Compliance PowerShell, for the `*-UnifiedAuditLogRetentionPolicy` cmdlets). `Microsoft.Graph` is used for licensing reads and the Audit Log Query API. **Why:** Audit is split across two S&C/Exchange endpoints plus Graph — the scripts use the right one for each task (GR §3). **Note:** retention-policy cmdlets are S&C PowerShell (`Connect-IPPSSession`); search/config cmdlets are Exchange Online (`Connect-ExchangeOnline`). **Verify:** `Get-Module -ListAvailable ExchangeOnlineManagement`; both `Connect-ExchangeOnline` and `Connect-IPPSSession` succeed with a modern-auth/MFA admin. `PURVAUDIT-Discovery.ps1` connects and reports which endpoints are reachable. **Implement:** `Install-Module ExchangeOnlineManagement -Scope CurrentUser`; `Install-Module Microsoft.Graph -Scope CurrentUser`.

2.4 Unified audit logging enabled

Description: `UnifiedAuditLogIngestionEnabled` must be **true** for the tenant. It is on by default for newer tenants but may be off (older tenants, or if disabled). **Why:** No searchable audit records are written while ingestion is off — and it is not retroactive (GR §6 discipline: change under control). **Verify:** `Get-AdminAuditLogConfig | Format-List UnifiedAuditLogIngestionEnabled` (via `Connect-ExchangeOnline`); `PURVAUDIT-Discovery.ps1` reports the state. **Implement:** `Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled $true` (may take time to fully activate) — `PURVAUDIT-Set-RetentionPolicy.ps1 -EnableUnifiedAudit -Commit` performs this under the pilot/change discipline.

2.5 Mailbox auditing on (and no unexpected bypass)

Description: Mailbox auditing (which produces `MailItemsAccessed`, `Send`, `New-InboxRule`, etc.) should be enabled org-wide, and no in-scope mailbox should be on the **audit bypass** list. **Why:** Mailbox audit bypass silently suppresses mailbox events for an account — a common reason an investigation finds "nothing" for a specific user. **Verify:** `Get-OrganizationConfig | Format-List AuditDisabled` (should be `False`); `PURVAUDIT-Discovery.ps1` reports org mailbox-audit state and enumerates any `Get-MailboxAuditBypassAssociation` where bypass is enabled. **Implement:** Ensure `AuditDisabled` is `False`; remove unintended bypass with `Set-MailboxAuditBypassAssociation -AuditBypassEnabled $false` (change-controlled).

2.6 Defined retention & investigation requirements (from compliance/legal)

Description: A documented statement — **from your compliance, records, privacy, and legal functions** — of how long which audit evidence must be retained, and which incident scenarios must be answerable. **Why:** Retention duration and legal-hold obligations are governance determinations, not technical defaults (GR §5); the solution configures to them, it does not decide them. **Verify:** You can name the required retention per record-type class (e.g. privileged actions, mailbox high-value, sign-ins) and the investigation scenarios in scope, with named approvers. **Implement:** Capture the retention/investigation requirements and approvals before authoring retention policies.

2.7 SIEM / export target and its identity (if exporting)

Description: A destination for continuous audit export — a **SIEM** (Microsoft Sentinel, Splunk, etc.) and, for the **Office 365 Management Activity API**, an **Entra app registration** with `ActivityFeed.Read` (and `ActivityFeed.ReadDlp` for DLP events), authenticating with a **certificate** (no client secret in scripts). **Why:** Export enables continuous monitoring and retention beyond the audit store; the Management Activity API needs an app identity with the right permissions. **Verify:** The SIEM/target is identified; the app registration exists with the API permissions granted (admin consent); `PURVAUDIT-Export.ps1` (read-only) lists current content subscriptions with the app's certificate. **Implement:** Register the app, grant + consent the `ActivityFeed.*` permissions, upload a certificate, and record the target — or plan to use a native connector (e.g. Sentinel's Office 365 / Microsoft 365 connector) instead of the raw API.

2.8 A pilot scope and change window

Description: A limited **pilot** — a small investigator group and a bounded set of record types — to validate search, retention, and export on before tenant-wide change, plus an agreed change window (GR §6). **Why:** Enabling ingestion, altering retention, and starting export are tenant-impacting; validate them small first. **Verify:** A named pilot scope (`Audit Pilot – Investigators – Stage1`) and change approval exist. **Implement:** Define the pilot group and change window before enabling or exporting anything.

Global Requirements — Microsoft Purview Solutions

These requirements apply to **every** solution in the **Purview** category (implementing and managing Microsoft Purview, sensitivity & retention labels, DLP, data lifecycle & records, insider risk, communication compliance, audit, data security posture management, and data governance). Verify each before starting a solution's implementation steps.

> ***Vendor boundary (applies to every Purview solution).*** *The **Microsoft Purview portal** (purview.microsoft.com), the **Microsoft 365 admin center**, **Security & Compliance PowerShell** (`Connect-IPPSSession`), and **Microsoft Graph** are authored at exact, current click-by-click / cmdlet detail from Microsoft's public documentation. Microsoft Purview features are heavily **licensing-/plan-dependent** (many require **Microsoft 365 E5** or the **E5 Compliance** add-on; some are in preview) and the portal is **actively evolving** — capability availability and portal paths are **cited or flagged "verify your licensing/tenant"**, never asserted or invented. **Regulatory, records-retention, and legal determinations** (retention schedules, records file plans, legal holds, insider-risk case actions, regulatory applicability) are **deferred to the organization's compliance, records, privacy, and legal functions** — the solutions provide the technical configuration method and evidence, not the determination. Automation is **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets.*

1. Microsoft 365 tenant with the required Purview/compliance licensing

- **Description:** A Microsoft 365 tenant with the **compliance licensing** the capability requires

(E3 for baseline; **E5 / E5 Compliance** for advanced DLP, auto-labeling, insider risk, communication compliance, Audit Premium, DSPM, etc.).

- **Why required:** Most Purview capabilities are plan-gated; the feature won't be available without the

right plan.

- **How to verify:** In the M365 admin center confirm the subscription/add-ons; check the feature is

visible in the Purview portal.

- **How to implement if missing:** Assign/purchase the required licensing before starting.

2. Purview roles (least-privilege) and portal access

- **Description:** Access with the least-privilege **Purview / compliance role** the solution names

(e.g. Compliance Administrator, Compliance Data Administrator, Information Protection, Records Management, Insider Risk, eDiscovery, Audit roles), with Global Administrator only where required.

- **Why required:** Purview uses fine-grained role groups; configuration requires the matching role.
- **How to verify:** Purview portal → **Roles & scopes / Permissions** — confirm the role membership.
- **How to implement if missing:** Assign the least-privilege role group under change control.

3. Security & Compliance PowerShell + Graph toolchain

- **Description:** A workstation with **Security & Compliance PowerShell** (`Connect-IPPSSession` via the

ExchangeOnlineManagement module) and **Microsoft Graph PowerShell**, modern-auth / MFA-capable admin.

- **Why required:** Configuration, automation, and the provided scripts run through these.
- **How to verify:** `Connect-IPPSSession` and `Connect-MgGraph` succeed with the admin account.
- **How to implement if missing:** Install the modules and confirm modern-auth sign-in before running steps.

4. Data sources & scope in scope

- **Description:** The **workloads and data sources** in scope (Exchange, SharePoint, OneDrive, Teams,

endpoints/devices, and — for data governance — the broader data estate) and a **data-classification / sensitivity** intent to drive labels, DLP, and retention.

- **Why required:** Purview policies key off the in-scope workloads and the classification scheme.
- **How to verify:** Confirm the in-scope workloads and the classification/sensitivity approach with

stakeholders.

• **How to implement if missing:** Define the scope and classification intent before authoring policies.

5. Compliance, records, privacy & legal stakeholders

• **Description:** Engagement with the **compliance, records-management, privacy, security, and legal**

stakeholders whose policies the configuration must satisfy (retention schedules, records file plans, regulatory obligations, insider-risk and communication-compliance policy, legal hold).

• **Why required:** Purview configuration must align to enterprise policy and legal/records requirements,

not technical defaults; several capabilities have HR/legal sensitivity.

• **How to verify:** Confirm the applicable policies, the records schedule, and named approvers.

• **How to implement if missing:** Identify the owners and capture the requirements before configuring.

6. A pilot scope and change control

• **Description:** A **pilot scope** (users/sites/policies in simulation or a limited ring) to validate

on before tenant-wide enforcement, and a **change-control** process — most Purview policies support a **simulation / test / disabled** mode that MUST be used before enforcement.

• **Why required:** Every solution follows an **Assess → Design → Configure → Pilot (simulate) → Validate

→ Expand (enforce)** model; DLP, labels, retention, and insider-risk changes are high-impact.

• **How to verify:** Confirm a named pilot scope, that simulation/test mode is available, and a change

window/approval path.

• **How to implement if missing:** Define the pilot and agree change control before enforcing anything.

*The deployment model across every Purview solution is the same: **Assess** → **Design** → **Configure** → **Pilot (simulate/test)** → **Validate** → **Expand (enforce)**, with explicit pass/fail gates and a documented rollback. Automation is delivered as **PowerShell** (Security & Compliance PowerShell / Graph) — never with hardcoded credentials or secrets. Regulatory/records/legal determinations are deferred to the relevant governance functions.*

3. Implementation Guide — Microsoft Purview Audit (Standard & Premium)

Follow these steps **in order**. Configuration uses the **Microsoft Purview portal** (`https://purview.microsoft.com`), **Exchange Online PowerShell** (`Connect-ExchangeOnline` — search, `Get/Set-AdminAuditLogConfig`, mailbox audit), **Security & Compliance PowerShell** (`Connect-IPPSSession` — the `*-UnifiedAuditLogRetentionPolicy` cmdlets), and **Microsoft Graph** (licensing, Audit Log Query API). Every write is gated: scripts run **read-only or** `-WhatIf` **by default** and only change state with `-Commit`. Artifact names follow the `<Purpose> – <Scope> – <Stage>` convention from the Overview and are reused verbatim.

> ***Model:*** *Assess what auditing/licensing you have, design the coverage, configure logging/retention/export,* ***pilot*** *on a limited scope in read/report mode, validate you can answer the incident questions, then expand. Pattern:* ***Assess*** *→* ***Design*** *→* ***Configure*** *→* ***Pilot*** *→* ***Validate*** *→* ***Expand. Audit is not retroactive*** *— every day this is deferred is a day of history you will not have.*

Step 1 — Assess the current audit state and licensing (Assess)

1. Run `PURVAUDIT-Discovery.ps1` (read-only). It connects to Exchange Online, S&C PowerShell, and Graph and reports:

• `UnifiedAuditLogIngestionEnabled` (is unified audit on?),

• org mailbox-audit state (`AuditDisabled`) and any mailbox **audit-bypass** associations,

• whether an **Audit Premium**-bearing plan (E5 / Audit add-on) is present and how many users carry it,

• existing **audit log retention policies** (`Get-UnifiedAuditLogRetentionPolicy`).

1. In the Purview portal, confirm **Audit** is visible under `Solutions → Audit` (visibility depends on role and licensing — Requirement 2.1/2.2).

2. Record the gaps: logging off, Premium not licensed where expected, unexpected bypass, no retention policies. These drive the steps below. **Pass gate:** you have a written current-state for each item.

Step 2 — Design the retention and investigation coverage (Design)

1. With your compliance/records/legal stakeholders (Requirement 2.6), agree the retention per record-type class and map it to the three standard policies:

• `Audit Retention – Mailbox High-Value – Premium` — Exchange mailbox high-value events (`MailItemsAccessed`, `Send`, `SendAs`, inbox-rule operations).

• `Audit Retention – Privileged Actions – LongTerm` — Entra/admin privileged operations (role adds, app consents, credential/MFA changes).

• `Audit Retention – Sign-in Events – Standard+` — authentication events (`UserLoggedIn`, `MailboxLogin`).

1. Agree the investigation scenarios and their runbooks (`Investigation – Mailbox Compromise – Runbook`, `Investigation – Data Exfiltration – Runbook`, `Investigation – Privilege Escalation – Runbook`) — Step 6 builds them.

2. Define the **pilot scope** `Audit Pilot – Investigators – Stage1` (Requirement 2.8). **Pass gate:** retention durations, runbooks, and pilot are documented and approved.

Step 3 — Enable the foundation: unified audit + mailbox auditing (Configure)

1. If Step 1 showed unified audit **off**, enable it under change control:

`PURVAUDIT-Set-RetentionPolicy.ps1 -EnableUnifiedAudit -WhatIf` → review → re-run with `-Commit`. (This runs `Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled $true`; activation can take time.)

1. Confirm org mailbox auditing is on (`AuditDisabled = False`) and remove any **unintended** audit-bypass (Requirement 2.5) — change-controlled, one account at a time, with justification.

2. **Pass gate:** re-run `PURVAUDIT-Discovery.ps1` — ingestion is `True`, mailbox auditing on, no unexpected bypass. **Rollback:** enabling audit is non-destructive; if a bypass removal is questioned, re-add it (`-AuditBypassEnabled $true`) pending review.

Step 4 — Configure audit log retention policies (Configure)

1. Create the three designed policies with the helper, **pilot-first** (`-WhatIf` prints the exact `New-UnifiedAuditLogRetentionPolicy` it would run):

• `PURVAUDIT-Set-RetentionPolicy.ps1 -PolicyName "Audit Retention – Mailbox High-Value – Premium" -RecordTypes ExchangeItem -Operations MailItemsAccessed,Send,SendAs,New-InboxRule,Set-InboxRule -Duration TenYears -Priority 100 -WhatIf`

• `PURVAUDIT-Set-RetentionPolicy.ps1 -PolicyName "Audit Retention – Privileged Actions – LongTerm" -RecordTypes AzureActiveDirectory -Duration TenYears -Priority 200 -WhatIf`

• `PURVAUDIT-Set-RetentionPolicy.ps1 -PolicyName "Audit Retention – Sign-in Events – Standard+" -RecordTypes AzureActiveDirectoryStsLogon -Duration OneYear -Priority 300 -WhatIf`

1. Review each `-WhatIf` line. Confirm the **record types**, **operations**, **duration**, and a **unique priority** (lower = evaluated first). **Verify accepted** `RetentionDuration` **values and that the ten-year tier is licensed in your tenant** (Requirement 2.1) before committing.

2. Re-run each with `-Commit` to create the policy in Security & Compliance PowerShell.

3. **Pass gate:** `PURVAUDIT-Discovery.ps1` lists the three policies with the expected durations/priorities. **Rollback:** `PURVAUDIT-Set-RetentionPolicy.ps1 -PolicyName "<name>" -Remove -Commit` (removes the policy; already-retained records age out by remaining rules).

Step 5 — Validate high-value events are being captured (Configure → Pilot)

1. For a **pilot mailbox** that carries Audit Premium, generate benign activity (open a message, send a test mail), wait for latency, then run:

```
PURVAUDIT-Search.ps1 -Operations MailItemsAccessed,Send -UserIds pilot.user@contoso.com -Start (Get-Date).AddDays(-1) -End (Get-Date)
```

1. Confirm `MailItemsAccessed` / `Send` records appear for the licensed pilot user. If they don't, check the license (2.1), mailbox auditing (2.5), and bypass — not the search.

2. **Pass gate:** high-value events are present for a licensed user. This is the concrete proof Premium is working; unlicensed users legitimately won't show these.

Step 6 — Build the investigation runbooks (Configure)

Encode the standard incident questions as saved, repeatable searches. Each runbook is a documented set of `PURVAUDIT-Search.ps1` invocations (operations + record types) with a short "what this answers":

1. `Investigation – Mailbox Compromise – Runbook`:

• Which messages did the attacker read? → `-Operations MailItemsAccessed` (Premium).

• Did they create forwarding/inbox rules? → `-Operations New-InboxRule,Set-InboxRule,UpdateInboxRules,Set-Mailbox`.

• Suspicious sign-ins? → `-Operations UserLoggedIn,MailboxLogin -RecordType AzureActiveDirectoryStsLogon` (corroborate with Entra sign-in logs).

1. `Investigation – Data Exfiltration – Runbook`:

• What did a departing user download/sync? → `-Operations FileDownloaded,FileSyncDownloadedFull -RecordType SharePointFileOperation`.

• Large or unusual searches? → `-Operations SearchQueryInitiatedExchange,SearchQueryInitiatedSharePoint` (Premium).

• External sharing? → `-Operations SharingInvitationCreated,AnonymousLinkCreated`.

1. `Investigation – Privilege Escalation – Runbook`:

• Who was added to a privileged role/group? → `-Operations "Add member to role.","Add member to group."`.

• App consent / credential abuse? → `-Operations "Consent to application.","Add app role assignment grant to user.","Update user."`.

1. Store each runbook (the exact commands + interpretation notes) alongside this guide. **Pass gate:** each runbook returns results against test/benign activity for a licensed user.

Step 7 — Wire SIEM/export (Configure → Pilot)

1. Decide the export path (Requirement 2.7): the **Office 365 Management Activity API** (this solution's helper) or a **native connector** (e.g. Microsoft Sentinel's Microsoft 365 / Office 365 connector — lower-effort, recommended where available).

2. For the Management Activity API, list current subscriptions read-only:

```
PURVAUDIT-Export.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> -Action ListSubscriptions
```

1. Start the content subscriptions you need (pilot with one content type first):

`PURVAUDIT-Export.ps1 ... -Action StartSubscription -ContentType Audit.AzureActiveDirectory -WhatIf` → review → `-Commit`. Repeat for `Audit.Exchange`, `Audit.SharePoint`, `Audit.General` as scoped. Label the effort `Audit Export – Management Activity API – SIEM`.

1. **Pass gate:** subscriptions show `enabled`; your SIEM receives content blobs. **Rollback:** `-Action StopSubscription -ContentType <type> -Commit`.

Step 8 — Validate investigation-readiness (Validate)

1. Run `PURVAUDIT-Report.ps1` to produce `Audit Readiness – Tenant – Report` — a scorecard across: unified audit on, Premium licensed where expected, high-value events present in recent data, the three retention policies in place, and export active.

2. Walk the runbooks (Step 6) against the pilot scope and confirm each incident question returns an answer. Complete the **Testing Guide** before expanding.

3. **Pass gate:** the readiness report is green on every gate for the pilot scope.

Step 9 — Expand and operationalize (Expand)

1. Once the pilot passes, extend retention/export coverage to the full agreed scope and confirm Premium licensing covers all users who need high-value events.

2. Schedule the read-only chain (`PURVAUDIT-Discovery.ps1` → `PURVAUDIT-Report.ps1`) on a cadence so drift — logging disabled, a new bypass, a lapsed license, a stopped subscription — is caught early, and re-run the runbooks during real investigations.

3. Hand the runbooks and the readiness report to your SOC/investigators as the standing procedure. **Pass gate:** readiness is green tenant-wide and the monitoring cadence is scheduled.

5. Testing & Validation — Microsoft Purview Audit (Standard & Premium)

Work through every gate. Each has a **method**, an **expected result (pass)**, and a **fail action**. Tests are read-only or use benign, self-generated activity — no production data is altered. Do not declare "investigation-ready" until every gate passes for the pilot scope, then re-confirm on expand.

> ***Remember:*** *audit is not retroactive. These tests confirm capture and retention* ***from now forward****; they cannot recover events from before logging/Premium was enabled.*

Gate 1 — Unified audit logging is on

• **Method:** `PURVAUDIT-Discovery.ps1`, or `Get-AdminAuditLogConfig | FL UnifiedAuditLogIngestionEnabled` (Exchange Online PowerShell).

• **Pass:** `UnifiedAuditLogIngestionEnabled = True`.

• **Fail:** enable via `PURVAUDIT-Set-RetentionPolicy.ps1 -EnableUnifiedAudit -Commit` (Implementation Step 3); allow activation time, then retest.

Gate 2 — Mailbox auditing on, no unexpected bypass

• **Method:** `PURVAUDIT-Discovery.ps1` — org `AuditDisabled` and the enumerated audit-bypass associations.

• **Pass:** `AuditDisabled = False`; no in-scope mailbox has `AuditBypassEnabled = True` unintentionally.

• **Fail:** correct org config; remove unintended bypass (`Set-MailboxAuditBypassAssociation -AuditBypassEnabled $false`) under change control; retest.

Gate 3 — Audit Premium licensing where expected

- **Method:** `PURVAUDIT-Discovery.ps1` licensing section (Graph `subscribedSkus` / service plans).
- **Pass:** an Audit Premium-bearing plan (E5 / Audit add-on) is present and assigned to the users who must have high-value events.
- **Fail:** assign the license (Requirement 2.1); unlicensed users will not produce `MailItemsAccessed` — that is expected, not a defect.

Gate 4 — High-value events are being captured

- **Method:** for a **licensed** pilot mailbox, generate benign activity (open a message, send a test mail), wait for latency, then `PURVAUDIT-Search.ps1 -Operations MailItemsAccessed,Send -UserIds pilot.user@contoso.com -Start (Get-Date).AddDays(-1) -End (Get-Date)`.
- **Pass:** `MailItemsAccessed` and/or `Send` records return for the licensed pilot user.
- **Fail:** re-check license (Gate 3), mailbox auditing (Gate 2), and bypass; allow for ingestion latency before concluding.

Gate 5 — Retention policies exist and are correct

- **Method:** `PURVAUDIT-Discovery.ps1` retention section (`Get-UnifiedAuditLogRetentionPolicy`).
- **Pass:** the three policies (`Audit Retention – Mailbox High-Value – Premium`, … `Privileged Actions – LongTerm`, … `Sign-in Events – Standard`+) exist with the agreed durations and unique priorities.
- **Fail:** create/correct with `PURVAUDIT-Set-RetentionPolicy.ps1` (Step 4); verify the `RetentionDuration` value and ten-year licensing.

Gate 6 — Search returns complete (non-truncated) results

- **Method:** run `PURVAUDIT-Search.ps1` over a window with more than a few hundred events and confirm it pages (`ReturnLargeSet`) rather than stopping at the first block.
- **Pass:** the result count matches expectation and the script reports it paged to completion (no silent truncation).
- **Fail:** narrow the time window and re-run; confirm paging is engaged. Very large windows should be split.

Gate 7 — Investigation runbooks answer their questions

- **Method:** walk each runbook (Implementation Step 6) against benign/test activity for a licensed user — mailbox compromise (`MailItemsAccessed`, inbox rules, sign-ins), data exfiltration (`FileDownloaded`, search operations, sharing), privilege escalation (role/group adds, app consent).
- **Pass:** each runbook returns interpretable results for its test activity.

• **Fail:** confirm the operation/record-type names and licensing for that scenario; adjust the runbook and retest.

Gate 8 — Export/SIEM is flowing (if configured)

• **Method:** `PURVAUDIT-Export.ps1 -Action ListSubscriptions` and confirm the SIEM is receiving content.

• **Pass:** the scoped content subscriptions show `enabled`; the SIEM ingests recent audit blobs.

• **Fail:** (re)start the subscription (`-Action StartSubscription -Commit`); verify the app's `ActivityFeed.*` permissions and certificate.

Gate 9 — Readiness scorecard is green

• **Method:** `PURVAUDIT-Report.ps1` → `Audit Readiness – Tenant – Report`.

• **Pass:** every gate above is green for the pilot scope (and, on expand, tenant-wide).

• **Fail:** address the specific red item and re-run.

Evidence to retain

• `PURVAUDIT-Discovery.ps1` and `PURVAUDIT-Report.ps1` outputs (before/after).

• The `-WhatIf` transcripts for every retention-policy and export change.

• The runbook results demonstrating each incident question is answerable.

• The list of pilot users and the change approvals (Requirement 2.6/2.8).

*Retention-duration adequacy and legal-hold sufficiency are **compliance/records/legal determinations** — these gates prove the technical configuration works, not that the retention schedule is correct.*

6. Troubleshooting — Microsoft Purview Audit (Standard & Premium)

The failure modes that make audit "find nothing," plus the configuration and export issues you'll hit. Each: **symptom** → **likely cause** → **fix.** Many "audit is broken" reports are actually latency, licensing, or bypass — this guide separates those from real faults.

Search returns nothing for a user you know was active

• **Cause A — ingestion latency.** Recent activity isn't searchable immediately; events can take time to appear. **Fix:** widen the window into the past and retest before concluding absence. `PURVAUDIT-Search.ps1` reminds you of this when it returns zero.

• **Cause B — high-value events aren't licensed.** `MailItemsAccessed`, `Send`, `SearchQueryInitiated*` only exist for users with **Audit Premium** (E5 / Audit add-on) assigned. An unlicensed user legitimately shows none. **Fix:** confirm the per-user license (`PURVAUDIT-Discovery.ps1` licensing section); document "no high-value events = unlicensed, not

all-clear."

• **Cause C — mailbox audit bypass.** The account is on the audit-bypass list, silently suppressing its mailbox events. **Fix:** `PURVAUDIT-Discovery.ps1` enumerates bypass; remove unintended bypass with `Set-MailboxAuditBypassAssociation -Identity <user> -AuditBypassEnabled $false`.

• **Cause D — unified audit is off.** No records are being written at all. **Fix:** enable it (Step 3); note it is **not retroactive**.

Search returns far fewer results than expected (truncation)

• **Cause:** `Search-UnifiedAuditLog` caps a single call's results; without paging you silently get only the first block.

• **Fix:** always page with `SessionCommand ReturnLargeSet` and a stable `SessionId` (the provided `PURVAUDIT-Search.ps1` does this and prints the running total) and **keep the time window short** — split large windows into smaller ones.

`UnifiedAuditLogIngestionEnabled` won't flip to True / is slow

• **Cause:** enabling ingestion can take time to fully activate; also requires the right role and a completed org customization.

• **Fix:** run `PURVAUDIT-Set-RetentionPolicy.ps1 -EnableUnifiedAudit -Commit`, then allow activation time and recheck with `PURVAUDIT-Discovery.ps1`. If the cmdlet errors on permissions, confirm the Audit/Exchange role (Requirement 2.2).

`MailItemsAccessed` still missing after licensing looks right

• **Cause:** org or per-mailbox mailbox auditing disabled, or the mailbox is bypassed, or the license was only just assigned (events start after activation).

• **Fix:** confirm `AuditDisabled = False` (`Get-OrganizationConfig`), remove bypass, and remember high-value events only accrue **after** the license and auditing are active — earlier history won't appear.

Retention policy cmdlet not found / "term not recognized"

• **Cause:** wrong endpoint. `New-/Set-/Get-/Remove-UnifiedAuditLogRetentionPolicy` are **Security & Compliance PowerShell** (`Connect-IPPSSession`), not Exchange Online.

• **Fix:** connect with `Connect-IPPSSession` for retention-policy work; use `Connect-ExchangeOnline` for `Search-UnifiedAuditLog` and `Get/Set-AdminAuditLogConfig`. Both ship in the `ExchangeOnlineManagement` module.

Retention policy create fails on duration or priority

• **Cause A — duration/licensing.** The `RetentionDuration` value isn't accepted for your plan, or `TenYears` is requested without the ten-year add-on. **Fix:** verify accepted `RetentionDuration` values and that the tier is licensed (Requirement 2.1) before `-Commit`.

• **Cause B — duplicate priority.** Priorities must be **unique**. **Fix:** pick an unused priority (e.g. 100/200/300); lower is evaluated first.

Retention policy doesn't seem to keep events

• **Cause:** a higher-priority (lower-number) broad policy is matching first, or the record types/operations don't match the events. **Fix:** review priority ordering and confirm the `RecordTypes`/`Operations` actually match the events (check a sample record's `RecordType`/`Operations` in `PURVAUDIT-Search.ps1` output). Note policies apply **going forward**.

Audit visible for some admins but not others

• **Cause:** missing Audit role. Searching needs **View-Only Audit Logs / Audit Logs** (packaged as **Audit Reader/Manager**).

• **Fix:** assign the least-privilege Audit role group (Requirement 2.2); Global Admin is not required just to search.

Management Activity API export: token or permission errors

• **Cause A — permissions/consent.** The app lacks `ActivityFeed.Read` (or `ActivityFeed.ReadDlp` for DLP) or admin consent wasn't granted. **Fix:** grant + consent the `ActivityFeed.*` application permissions in Entra.

• **Cause B — certificate.** The thumbprint isn't in the local store with its private key, or the cert isn't uploaded to the app. **Fix:** confirm `Cert:\CurrentUser\My\<thumb>` (or LocalMachine) resolves and the matching public cert is on the app registration. `PURVAUDIT-Export.ps1` uses certificate app-only auth — **no client secret**.

• **Cause C — subscription not started.** Listing shows the content type absent. **Fix:** `PURVAUDIT-Export.ps1 -Action StartSubscription -ContentType <type> -Commit`.

SIEM shows no data even though subscriptions are "enabled"

• **Cause:** the subscription is started but nothing is pulling/receiving the content blobs, or the connector is misconfigured.

• **Fix:** for the raw API, confirm your collector is calling `subscriptions/content` and retrieving blobs; consider a **native connector** (e.g. Microsoft Sentinel's Microsoft 365 / Office 365 connector) which handles polling for you. Verify with `PURVAUDIT-Export.ps1 -Action ListAvailableContent -ContentType <type>`.

Timestamps don't line up with other logs

• **Cause:** audit `CreationDate` is **UTC**.

• **Fix:** normalize to UTC when correlating with Entra sign-in logs, message trace, or endpoint logs.

When to escalate beyond this solution

- **Retention-schedule adequacy, legal hold, or regulatory obligation** questions → **compliance, records, privacy, and legal** functions (this solution configures to their schedule; it does not set it).
- **Suspected active compromise** → your incident-response process; use the runbooks to gather evidence, but containment/eradication is IR, not audit configuration.
- **Feature genuinely absent despite correct licensing** → verify against current Microsoft documentation and open a Microsoft support case; Purview capabilities and search tooling evolve.

7. Best Practices — Investigation-Ready Auditing with Microsoft Purview

Operating principles for keeping Purview Audit trustworthy and investigations fast. Grounded in Microsoft's public guidance and the **Assess** → **Design** → **Configure** → **Pilot** → **Validate** → **Expand** model.

Configure it before you need it

- **Audit is not retroactive** — the single most important rule. Enable unified audit logging, mailbox auditing, and Audit Premium (where licensed) **now**, so history exists when an incident asks for it. Every deferred day is permanently missing evidence.
- Treat "is auditing on?" as a **standing monitored control**, not a one-time check. Ingestion can be turned off and licenses can lapse; the scheduled `PURVAUDIT-Discovery.ps1`/`PURVAUDIT-Report.ps1` chain catches drift.

Understand — and license for — the events you'll actually need

- The events that make or break an investigation (`MailItemsAccessed`, `Send`, `SearchQueryInitiated*`) are **Premium** and **per-user licensed**. Decide *which* users must have forensic-grade auditing (executives, admins, finance, high-risk roles) and ensure they carry the license.
- Don't assume every user has high-value events. An unlicensed user showing no `MailItemsAccessed` is a **licensing fact, not an all-clear** — say so in the investigation write-up.

Retention: deliberate, priority-ranked, and governed

- Set **audit log retention policies** by record-type class rather than relying on the default. Keep privileged actions and mailbox high-value events the longest; keep noisy, low-value operations shorter.
- Priorities are **unique and lower-first** — plan the numbering (e.g. 100/200/300) so a specific policy wins over a broad one predictably.
- **Retention duration and legal-hold are compliance/records/legal determinations.** Configure to their schedule; don't invent one. Verify the ten-year tier is licensed before promising it.

Watch the gotchas that make audit "find nothing"

- **Mailbox audit bypass** silently suppresses a user's mailbox events — audit any bypass associations and remove unintended ones.

• **Ingestion latency** means recent activity may not appear immediately — allow time before concluding an event is absent.

• **Search truncation** — `Search-UnifiedAuditLog` caps results; always page (`ReturnLargeSet`) and keep windows short so you never silently miss records. The provided search tool does this.

• **Time zones / UTC** — audit timestamps are UTC; normalize when correlating with other logs.

Standardize investigations as runbooks

• Encode the common incident questions once (mailbox compromise, data exfiltration, privilege escalation) with the exact operations and record types. Under pressure, investigators run a procedure, not a memory test.

• **Corroborate across sources** — audit for user/admin actions, **Entra sign-in logs** for authentication detail, message trace for mail flow. No single log tells the whole story.

• Keep runbooks current as Microsoft renames/adds operations and shifts search tooling (portal, `Search-UnifiedAuditLog`, the Graph **Audit Log Query API**) — verify against current docs periodically.

Export for durability and monitoring — but keep identities clean

• Stream to a **SIEM** for real-time detection and retention beyond the audit store. Prefer a **native connector** (e.g. Microsoft Sentinel) where available; use the **Management Activity API** app when you need the raw feed.

• The export app authenticates with a **certificate, never a client secret in code**. Grant least-privilege (`ActivityFeed.Read`, add `ActivityFeed.ReadDlp` only if you need DLP events), and rotate the certificate.

Least-privilege roles and separation

• Give investigators **Audit Reader**; give the configuring admin **Audit Manager**. Reserve Global Administrator for one-time enablement.

• Access to the audit log is itself sensitive (it reveals who did what) — review Audit role membership periodically and log configuration changes.

Pilot every change, keep a rollback

• Enable, retain, and export **pilot-first** on a limited scope in `-WhatIf`/read mode; validate with the readiness report before tenant-wide expansion.

• Retention-policy and export changes are reversible (`-Remove`, `StopSubscription`) — record the exact rollback with every change so a questioned change can be backed out cleanly.

8. Deliverables Summary — Microsoft Purview Audit (Standard & Premium)

What you receive, what to run, and what "done" looks like.

Documentation

Document	Purpose
1. Solution Overview	What Purview Audit is, Standard vs Premium, the audit stack, what you control, honest limitations, and the naming convention.
2. Requirements Guide	Audit-specific prerequisites (licensing tier, Audit roles, Exchange Online + S&C PowerShell + Graph toolchain, logging/mailbox-audit state, export identity, pilot) — each with Verify / Implement.
3. Implementation Guide	Ordered steps: assess, design, enable logging, configure retention policies, validate high-value events, build investigation runbooks, wire export, validate readiness, expand — pilot-first with pass/fail gates and rollback.
5. Testing & Validation	Nine gates from "logging on" to "readiness scorecard green," each with method / pass / fail action.
6. Troubleshooting	The failure modes that make audit "find nothing" — bypass, latency, truncation, licensing, endpoint confusion, export auth — and their fixes.
7. Best Practices	Investigation-ready operating principles: configure before you need it, license the right users, deliberate retention, runbooks, clean export identities, least-privilege roles.

PowerShell tools (5)

All run **read-only or `-WhatIf` by default**; writes require `-Commit`. No credentials or secrets are embedded. Retention-policy cmdlets use **Security & Compliance PowerShell** (`Connect-IPPSSession`); search/config use **Exchange Online PowerShell** (`Connect-ExchangeOnline`); licensing/query use **Microsoft Graph**.

Script	Role	Default
`PURVAUDIT-Discovery.ps1`	Assess: unified-audit state, org mailbox auditing + bypass, Audit Premium licensing, existing retention policies.	Read-only
`PURVAUDIT-Set-RetentionPolicy.ps1`	Configure/Remediate: enable unified audit; create/update/remove audit log retention policies.	`-WhatIf` (writes on `-Commit`)

Script	Role	Default
`PURVAUDIT-Search.ps1`	Investigate: paged `Search-UnifiedAuditLog` by operation / record type / user / window (no silent truncation).	Read-only
`PURVAUDIT-Report.ps1`	Validate: investigation-readiness scorecard across logging, licensing, high-value events, retention, export.	Read-only
`PURVAUDIT-Export.ps1`	Configure: list/start/stop Office 365 Management Activity API content subscriptions (certificate app-only auth).	Read-only (writes on `-Commit`)

Named artifacts created

- Retention policies: `Audit Retention – Mailbox High-Value – Premium`, `Audit Retention – Privileged Actions – LongTerm`, `Audit Retention – Sign-in Events – Standard+`.
- Investigation runbooks: `Investigation – Mailbox Compromise – Runbook`, `Investigation – Data Exfiltration – Runbook`, `Investigation – Privilege Escalation – Runbook`.
- Export subscription effort: `Audit Export – Management Activity API – SIEM`.
- Readiness export: `Audit Readiness – Tenant – Report`. Pilot scope: `Audit Pilot – Investigators – Stage1`.

Definition of done

- Unified audit logging **on**; mailbox auditing on with no unintended bypass.
- Audit Premium **licensed** for the users who need high-value events, and `MailItemsAccessed`/`Send` **confirmed present** for a licensed pilot user.
- The three **retention policies** in place with agreed durations/priorities.
- The three **investigation runbooks** proven to answer their questions.
- Export flowing to the SIEM (if in scope), and the **readiness scorecard green** for the pilot — then expanded tenant-wide with a monitoring cadence scheduled.

Boundary: *this solution delivers the technical configuration and evidence.* ***Retention-schedule adequacy, legal-hold obligations, and any regulatory determination are deferred to your compliance, records, privacy, and legal functions.*** *Feature availability is* ***licensing-/tenant-dependent and evolving — verify against your entitlements and current Microsoft documentation.***

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

PURVAUDIT-Discovery.ps1

Purpose: Reports the current audit posture with no changes: whether unified audit log ingestion is on, org-level mailbox auditing state and any mailbox audit-bypass associations, whether an Audit Premium-bearing plan (E5 / Audit add-on) is present and how many users carry it, and the existing audit log retention policies. Read-only. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\PURVAUDIT-Discovery.ps1 Requires the ExchangeOnlineManagement module (Connect-ExchangeOnline + Connect-IPPSSession) and, for the licensing section, Microsoft.Graph with delegated Organization.Read.All / Directory.Read.All. Uses an interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A posture summary: UnifiedAuditLogIngestionEnabled True/False, AuditDisabled True/False, any bypassed mailboxes, Audit Premium plan present Yes/No with an assigned-user count, and the list of retention policies. Any "verify your licensing/tenant" item is flagged, not asserted. .NOTES Purview category — Audit (Standard & Premium). Read-only. Feature availability is licensing-/tenant- dependent and evolving; confirm against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$UserPrincipalName, # optional: admin UPN to pass to Connect-* prompts [switch]$SkipGraphLicensing # skip the Graph licensing section if Graph is unavailable)

How to run: powershell -ExecutionPolicy Bypass -File .\PURVAUDIT-Discovery.ps1 Requires the ExchangeOnlineManagement module (Connect-ExchangeOnline + Connect-IPPSSession) and, for the licensing section, Microsoft.Graph with delegated Organization.Read.All / Directory.Read.All. Uses an interactive modern-auth / MFA admin sign-in; no secrets in code. EXPECTED RESULTS A posture summary: UnifiedAuditLogIngestionEnabled True/False, AuditDisabled True/False, any bypassed mailboxes, Audit Premium plan present Yes/No with an assigned-user count, and the list of retention policies. Any "verify your licensing/tenant" item is flagged, not asserted. .NOTES Purview category — Audit (Standard & Premium). Read-only. Feature availability is licensing-/tenant- dependent and evolving; confirm against your entitlements and current Microsoft documentation. > [CmdletBinding()] param([string]$UserPrincipalName, # optional: admin UPN to pass to Connect-* prompts [switch]$SkipGraphLicensing # skip the Graph licensing section if Graph is unavailable)

PURVAUDIT-Export.ps1

Purpose: Lists, starts, or stops Office 365 Management Activity API content subscriptions so audit data can stream to a SIEM. SAFE BY DEFAULT: -Action ListSubscriptions is read-only; StartSubscription / StopSubscription only change state with -Commit (otherwise they preview). Authenticates app-only with a CERTIFICATE (thumbprint) — never a client secret in code. HOW TO RUN List current subscriptions (read-only): powershell -File .\PURVAUDIT-Export.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> -Action ListSubscriptions Start a content type (preview then commit): .\PURVAUDIT-Export.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> ` -Action StartSubscription -ContentType Audit.AzureActiveDirectory -WhatIf .\PURVAUDIT-Export.ps1 ... -Action StartSubscription -ContentType Audit.AzureActiveDirectory -Commit Requires an Entra app registration with ActivityFeed.Read (ActivityFeed.ReadDlp for DLP), admin- consented, and a certificate uploaded to the app (private key available locally by thumbprint). Native SIEM connectors (e.g. Microsoft Sentinel) are a lower-effort alternative to this raw API. EXPECTED RESULTS ListSubscriptions: the content types

currently enabled. Start/Stop under -Commit: the API confirms the subscription state; under -WhatIf: the exact call that would be made. .NOTES Purview category — Audit. Certificate app-only auth; NO secrets in code. Management Activity API is the manage.office.com resource. Confirm the app permissions/consent and content-type availability for your tenant. ContentType one of: Audit.AzureActiveDirectory, Audit.Exchange, Audit.SharePoint, Audit.General, DLP.All. > [CmdletBinding()] param([Parameter(Mandatory)] [string]$TenantId, [Parameter(Mandatory)] [string]$AppId, [Parameter(Mandatory)] [string]$CertificateThumbprint, [ValidateSet('ListSubscriptions','StartSubscription','StopSubscription','ListAvailableContent')] [string]$Action = 'ListSubscriptions', [ValidateSet('Audit.AzureActiveDirectory','Audit.Exchange','Audit.SharePoint','Audit.General','DLP.All')] [string]$ContentType, [switch]$Commit)

How to run: List current subscriptions (read-only): powershell -File .\PURVAUDIT-Export.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> -Action ListSubscriptions Start a content type (preview then commit): .\PURVAUDIT-Export.ps1 -TenantId <guid> -AppId <guid> -CertificateThumbprint <thumb> ` -Action StartSubscription -ContentType Audit.AzureActiveDirectory -WhatIf .\PURVAUDIT-Export.ps1 ... -Action StartSubscription -ContentType Audit.AzureActiveDirectory -Commit Requires an Entra app registration with ActivityFeed.Read (ActivityFeed.ReadDlp for DLP), admin-consented, and a certificate uploaded to the app (private key available locally by thumbprint). Native SIEM connectors (e.g. Microsoft Sentinel) are a lower-effort alternative to this raw API. EXPECTED RESULTS ListSubscriptions: the content types currently enabled. Start/Stop under -Commit: the API confirms the subscription state; under -WhatIf: the exact call that would be made. .NOTES Purview category — Audit. Certificate app-only auth; NO secrets in code. Management Activity API is the manage.office.com resource. Confirm the app permissions/consent and content-type availability for your tenant. ContentType one of: Audit.AzureActiveDirectory, Audit.Exchange, Audit.SharePoint, Audit.General, DLP.All. > [CmdletBinding()] param([Parameter(Mandatory)] [string]$TenantId, [Parameter(Mandatory)] [string]$AppId, [Parameter(Mandatory)] [string]$CertificateThumbprint, [ValidateSet('ListSubscriptions','StartSubscription','StopSubscription','ListAvailableContent')] [string]$Action = 'ListSubscriptions', [ValidateSet('Audit.AzureActiveDirectory','Audit.Exchange','Audit.SharePoint','Audit.General','DLP.All')] [string]$ContentType, [switch]$Commit)

PURVAUDIT-Report.ps1

Purpose: Produces a pass/fail readiness scorecard: unified audit ingestion on, org mailbox auditing on with no unexpected bypass, Audit Premium licensed (plan present), high-value events observed in a recent probe window, the expected retention policies present, and (optionally) export subscriptions active. Read-only — computes and reports, changes nothing. Optional CSV export. HOW TO RUN powershell -File .\PURVAUDIT-Report.ps1 -ProbeUser pilot.user@contoso.com -CsvPath .\Audit-Readiness.csv Requires ExchangeOnlineManagement (Connect-ExchangeOnline + Connect-IPPSSession) and, for the licensing gate, Microsoft.Graph. Interactive sign-in; no secrets in code. EXPECTED RESULTS A scorecard with PASS/FAIL/CHECK per gate and an overall readiness verdict; "Audit Readiness - Tenant - Report" material. FAIL rows point to the implementation step that fixes them. .NOTES Purview category — Audit. Read-only. Licensing/feature gates are tenant-dependent — CHECK results mean "verify your licensing/tenant", not a defect. Retention-schedule/legal adequacy is out of scope. > [CmdletBinding()] param([string[]]$ExpectedPolicies = @('Audit Retention - Mailbox High-Value - Premium','Audit Retention - Privileged Actions - LongTerm','Audit Retention - Sign-in Events - Standard+'), [string]$ProbeUser, # a licensed user to probe for high-value events [int]$ProbeDays = 7, [string]$CsvPath,

[string]$UserPrincipalName, [switch]$SkipGraphLicensing)

How to run: powershell -File .\PURVAUDIT-Report.ps1 -ProbeUser pilot.user@contoso.com -CsvPath .\Audit-Readiness.csv Requires ExchangeOnlineManagement (Connect-ExchangeOnline + Connect-IPPSSession) and, for the licensing gate, Microsoft.Graph. Interactive sign-in; no secrets in code. EXPECTED RESULTS A scorecard with PASS/FAIL/CHECK per gate and an overall readiness verdict; "Audit Readiness - Tenant - Report" material. FAIL rows point to the implementation step that fixes them. .NOTES Purview category — Audit. Read-only. Licensing/feature gates are tenant-dependent — CHECK results mean "verify your licensing/tenant", not a defect. Retention-schedule/legal adequacy is out of scope. > [CmdletBinding()] param([string[]]$ExpectedPolicies = @('Audit Retention - Mailbox High-Value - Premium','Audit Retention - Privileged Actions - LongTerm','Audit Retention - Sign-in Events - Standard+'), [string]$ProbeUser, # a licensed user to probe for high-value events [int]$ProbeDays = 7, [string]$CsvPath, [string]$UserPrincipalName, [switch]$SkipGraphLicensing)

PURVAUDIT-Search.ps1

Purpose: Runs Search-UnifiedAuditLog for an investigation by operation(s), record type, user(s), and time window, paging with ReturnLargeSet so results are NOT silently truncated. Read-only — it never changes tenant state. Use it directly or as the engine behind the investigation runbooks (mailbox compromise, data exfiltration, privilege escalation). HOW TO RUN Which messages did an attacker read, and did they set forwarding? (Premium: MailItemsAccessed) powershell -File .\PURVAUDIT-Search.ps1 -Operations MailItemsAccessed,New-InboxRule,Set-InboxRule ` -UserIds victim@contoso.com -Start (Get-Date).AddDays(-7) -End (Get-Date) -CsvPath .\out.csv Requires ExchangeOnlineManagement (Connect-ExchangeOnline) and the View-Only Audit Logs / Audit Logs role. Interactive modern-auth sign-in; no secrets in code. EXPECTED RESULTS A table (and optional CSV) of matching audit records with the paged total count. If zero, the script distinguishes "no events" from likely causes (latency, licensing for high-value events, mailbox bypass) so absence is not mistaken for an all-clear. .NOTES Purview category — Audit. Read-only. Search-UnifiedAuditLog has result/throttling limits — keep windows short; the script pages ReturnLargeSet. High-value operations (MailItemsAccessed, Send, SearchQueryInitiated*) require Audit Premium per user. Timestamps are UTC. > [CmdletBinding()] param([string[]]$Operations, # e.g. MailItemsAccessed, Send, New-InboxRule, FileDownloaded, "Add member to role." [string]$RecordType, # optional, e.g. ExchangeItem, AzureActiveDirectoryStsLogon, SharePointFileOperation [string[]]$UserIds, # optional scope by user [datetime]$Start = (Get-Date).AddDays(-7), [datetime]$End = (Get-Date), [string]$FreeText, # optional free-text filter [int]$ResultSizePerPage = 5000, [string]$CsvPath, [string]$UserPrincipalName)

How to run: Which messages did an attacker read, and did they set forwarding? (Premium: MailItemsAccessed) powershell -File .\PURVAUDIT-Search.ps1 -Operations MailItemsAccessed,New-InboxRule,Set-InboxRule ` -UserIds victim@contoso.com -Start (Get-Date).AddDays(-7) -End (Get-Date) -CsvPath .\out.csv Requires ExchangeOnlineManagement (Connect-ExchangeOnline) and the View-Only Audit Logs / Audit Logs role. Interactive modern-auth sign-in; no secrets in code. EXPECTED RESULTS A table (and optional CSV) of matching audit records with the paged total count. If zero, the script distinguishes "no events" from likely causes (latency, licensing for high-value events, mailbox bypass) so absence is not mistaken for an all-clear. .NOTES Purview category — Audit. Read-only. Search-UnifiedAuditLog has result/throttling limits — keep windows short; the script pages ReturnLargeSet. High-value operations (MailItemsAccessed, Send, SearchQueryInitiated*) require Audit Premium per user. Timestamps are UTC. > [CmdletBinding()] param([string[]]$Operations, # e.g. MailItemsAccessed, Send, New-InboxRule, FileDownloaded, "Add member to role." [string]$RecordType, # optional, e.g. ExchangeItem, AzureActiveDirectoryStsLogon,

SharePointFileOperation [string[]]$UserIds, # optional scope by user [datetime]$Start = (Get-Date).AddDays(-7), [datetime]$End = (Get-Date), [string]$FreeText, # optional free-text filter [int]$ResultSizePerPage = 5000, [string]$CsvPath, [string]$UserPrincipalName)

PURVAUDIT-Set-RetentionPolicy.ps1

Purpose: Configuration/remediation helper. With -EnableUnifiedAudit it turns unified audit log ingestion on. Otherwise it creates or updates an audit log retention policy (record types / operations / users / duration / priority), or removes one with -Remove. SAFE BY DEFAULT: prints the exact change under -WhatIf and only writes with -Commit. HOW TO RUN Preview enabling unified audit: powershell -File .\PURVAUDIT-Set-RetentionPolicy.ps1 -EnableUnifiedAudit -WhatIf Create a mailbox high-value retention policy (preview then commit): .\PURVAUDIT-Set-RetentionPolicy.ps1 -PolicyName "Audit Retention - Mailbox High-Value - Premium" `-RecordTypes ExchangeItem -Operations MailItemsAccessed,Send,SendAs,New-InboxRule,Set-InboxRule` -Duration TenYears -Priority 100 -WhatIf .\PURVAUDIT-Set-RetentionPolicy.ps1 ... -Commit Enable uses Exchange Online PowerShell (Connect-ExchangeOnline); retention-policy cmdlets use Security & Compliance PowerShell (Connect-IPPSSession). No secrets in code. EXPECTED RESULTS Under -WhatIf: the exact cmdlet that would run and its parameters. Under -Commit: the policy is created/updated/removed (or ingestion enabled) and the resulting object is printed. .NOTES Purview category — Audit. Retention duration/ten-year tier are LICENSING-DEPENDENT; verify accepted RetentionDuration values and licensing in your tenant before -Commit. Pilot-first per the guide. > [CmdletBinding()] param([switch]$EnableUnifiedAudit,

How to run: Preview enabling unified audit: powershell -File .\PURVAUDIT-Set-RetentionPolicy.ps1 -EnableUnifiedAudit -WhatIf Create a mailbox high-value retention policy (preview then commit): .\PURVAUDIT-Set-RetentionPolicy.ps1 -PolicyName "Audit Retention - Mailbox High-Value - Premium" `-RecordTypes ExchangeItem -Operations MailItemsAccessed,Send,SendAs,New-InboxRule,Set-InboxRule` -Duration TenYears -Priority 100 -WhatIf .\PURVAUDIT-Set-RetentionPolicy.ps1 ... -Commit Enable uses Exchange Online PowerShell (Connect-ExchangeOnline); retention-policy cmdlets use Security & Compliance PowerShell (Connect-IPPSSession). No secrets in code. EXPECTED RESULTS Under -WhatIf: the exact cmdlet that would run and its parameters. Under -Commit: the policy is created/updated/removed (or ingestion enabled) and the resulting object is printed. .NOTES Purview category — Audit. Retention duration/ten-year tier are LICENSING-DEPENDENT; verify accepted RetentionDuration values and licensing in your tenant before -Commit. Pilot-first per the guide. > [CmdletBinding()] param([switch]$EnableUnifiedAudit,